

Scanning & Vulnerability Discovery

Nmap: The Scanner You'll Never Stop Using

```
# Host discovery
nmap -sn 10.0.0.0/24          # ping sweep
# Port scanning
nmap -sS 10.0.0.5             # TCP SYN (stealth)
nmap -sT 10.0.0.5             # TCP connect
nmap -sU --top-ports 100 10.0.0.5 # UDP
nmap -p- 10.0.0.5             # ALL ports
# Service + version + OS
nmap -sV -O -p 22,80,443 10.0.0.5
# Script (NSE) â€” tons of detections
nmap --script default,http-enum,smb-vuln* 10.0.0.5
# Timing: -T4 aggressive
# Output: -oA out â†’ all formats
```

Read the output:

`open` â€” responded, service listening

`filtered` â€” firewall dropped

`closed` â€” reached, nothing there

Service/version â†’ search exploits (`searchsploit <service> <version>`)

From Open Ports to Vulnerability

Open port â†’ service + version â†’ CVE search:

```
# Identify the exact version to target
# e.g., Apache httpd 2.4.49 â†’ CVE-2021-41773 path traversal!
nmap -sV -p 80 10.0.0.5
searchsploit "apache 2.4.49"
```

CVSS Scoring (Read It Right)

CVSS 3.x = 0-10 score + vector:

Base "intrinsic (attack vector, complexity, privileges, user interaction)

Temporal "availability of exploit, patches

Environmental "your specific setup (damage to YOUR assets)

CVSS % risk. A CVSS 7 on an edge box exposed to the internet is riskier than the same 7 on an internal test server you're about to patch. Context, context, context.

Vulnerability Scanners: Nessus / OpenVAS

```
# OpenVAS (open-source) workflow:  
# 1. Create target  â†’  2. Create scan config  â†’  3. Launch  â†’  4. Review results  
# Nessus (commercial) similar, web GUI
```

How they work:

Port scan first

Version fingerprint

Match against a plugin database (CVEs)

Return: plugins, CVEs, CVSS, suggested fixes

Limits: scanners produce *potential* vulns; they need verification (module follows). They find low-hanging fruit, not architecture flaws, and can false-positive badly.

The Vulnerability Management Loop

Discover (scan, agent)

Assess (verify, prioritize)

Remediate (patch, config, mitigation)

Re-verify (rescan)

Report (trend to execs)

This loop runs weekly in every SOC/security team. You'll live it.

[← Reconnaissance & OSINT](#)

[Exploitation with Metasploit →](#)